Informe de seguridad de la aplicación móvil MackeUp AI: auditoría con el OWASP Mobile Top 10 (2024)

[Nombres de los integrantes del grupo]

Universidad Popular del Cesar

Programación Móvil

Alex Vacca

16 de noviembre de 2026

Resumen

Este informe presenta la auditoría de seguridad de MackeUp AI, una aplicación Flutter de asesoría de imagen con backend en Firebase, realizada con la lista OWASP Mobile Top 10 (2024). Se elaboró un modelo de amenazas, se revisaron los diez riesgos con seis técnicas (búsqueda de secretos con gitleaks, análisis de dependencias, revisión del manifiesto, análisis del APK de release, revisión de código de las reglas y de las Cloud Functions, y Logcat en un emulador) y se registraron nueve hallazgos: uno de severidad alta, cinco medios y tres bajos. El más grave fue que el APK de release se firmaba con una llave publicada en el repositorio público. Se corrigieron ocho hallazgos, cada uno en su propio commit, y se verificaron repitiendo la misma prueba antes y después de la corrección. Siete quedaron cerrados por completo, uno quedó cerrado de forma parcial con un riesgo residual justificado, y la integración con App Check quedó como mejora pendiente.

Palabras clave: seguridad móvil, OWASP Mobile Top 10, Flutter, Firebase, auditoría

Informe de seguridad de la aplicación móvil MackeUp AI: auditoría con el OWASP Mobile Top 10 (2024)

MackeUp AI analiza la colorimetría de la usuaria a partir de una selfie, recomienda maquillaje y ropa, ofrece un simulador de maquillaje en realidad aumentada, un asistente con inteligencia artificial y un módulo para marcas. Su backend usa Firebase Authentication, Cloud Firestore, Cloud Storage, Cloud Functions y Cloud Messaging. La auditoría siguió la guía de la asignatura (Vacca, 2026), que pide modelar las amenazas, auditar la app con el OWASP Mobile Top 10, corregir al menos cinco hallazgos y demostrar el antes y el después.

La regla base del trabajo es que el dispositivo y la aplicación instalada no son de confianza: toda decisión de permisos se valida en el servidor. Como marco de referencia se usaron el OWASP Mobile Top 10 (OWASP Foundation, 2024a), el estándar de verificación MASVS (OWASP Foundation, 2024b) y la guía de pruebas MASTG en su versión 2.0.0 (OWASP Foundation, 2026). Los cambios de la edición 2024 frente a la de 2016 se tomaron del resumen de Holloway-George (2024).

Se auditó la rama `feature/seguridad` del repositorio del proyecto en el commit `28fc2f7` (12 de noviembre de 2026). Las evidencias de este informe ocultan llaves, tokens y datos personales; los reportes completos de las herramientas se guardaron en `auditoria/evidencia/`, carpeta excluida del repositorio.

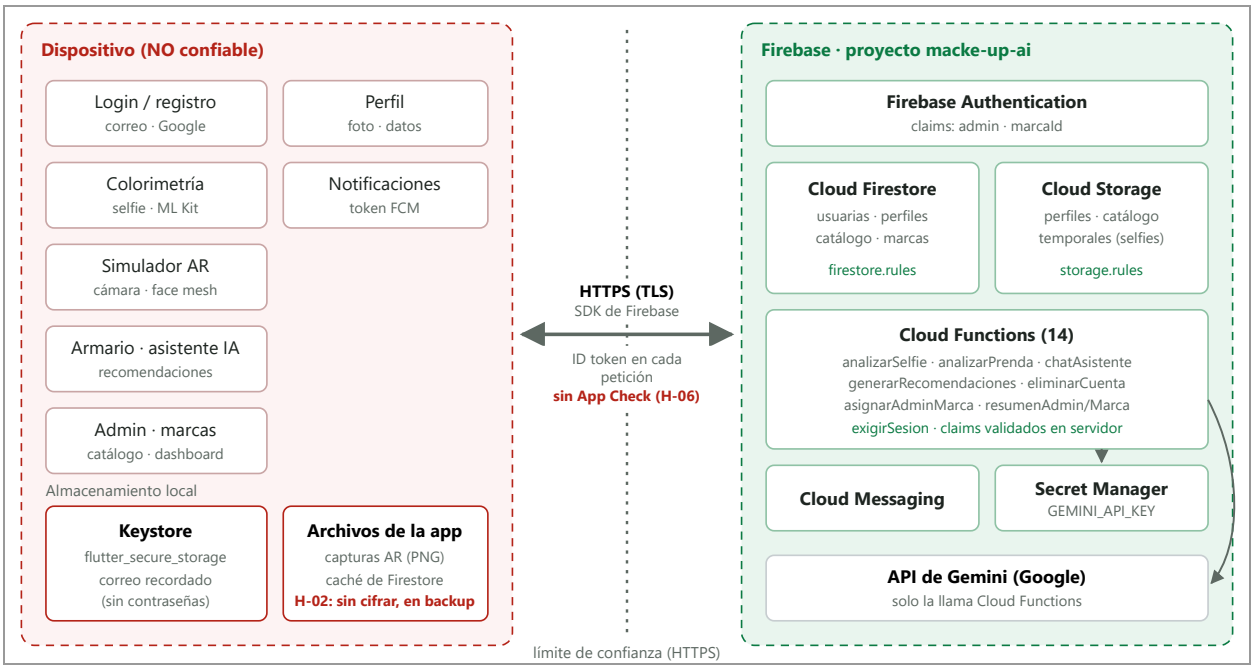
Método

Modelo de amenazas

La Figura 1 muestra los componentes de la aplicación, el límite de confianza entre el dispositivo y Firebase, y dónde se guarda cada dato. La Tabla 1 resume los datos sensibles y la Tabla 2 las amenazas identificadas.

Figura 1

Componentes de MackeUp AI y flujo de datos entre el dispositivo y Firebase



Nota. La única vía entre el dispositivo y el backend es el SDK de Firebase sobre HTTPS, con el ID token de la usuaria en cada petición. Elaboración propia.

Tabla 1

Datos sensibles que maneja la aplicación

Dato	Dónde se guarda	En tránsito	Sensibilidad
Correo y contraseña	Firebase Auth; en el dispositivo solo el correo (Keystore)	HTTPS a Auth	Alta
Sesión (ID token y refresh token)	SDK de Firebase Auth	Cabeceras a Functions	Alta
Selfie y fotos del rostro	Temporal de análisis; capturas AR en archivos de la app	HTTPS a Storage y Functions	Alta (biométrico)
Rol de administradora o de admin de marca	Custom claims del token	—	Alta
Perfil de colorimetría	Firestore `perfiles_colorimetria`	HTTPS	Media
Foto de perfil, conversaciones con la IA, armario	Storage y Firestore	HTTPS	Media

Dato	Dónde se guarda	En tránsito	Sensibilidad
Token de notificaciones (FCM)	Firestore `usuarias/{uid}`	HTTPS	Baja

Tabla 2

Amenazas identificadas y control esperado

ID	Amenaza	Quién	OWASP	Control esperado
A-01	Distribuir un APK modificado firmado con la misma llave que la app real, porque la llave está en el repositorio público.	Cualquiera que clone el repositorio	M1, M8	Llave de release privada (H-01)
A-02	Una marca desactivada o una ex-admin de marca sigue modificando el catálogo.	Ex-administradora de una marca	M3	Reglas que revisen marca activa y lista de admins (H-03)
A-03	Recuperar las fotos del rostro del simulador AR desde el respaldo de Google o una copia del teléfono.	Persona con acceso a la cuenta o al dispositivo	M9, M6	Excluir los datos del respaldo (H-02)
A-04	Llamar a las Cloud Functions con un script, sin la app, para gastar la cuota de Gemini o falsear estadísticas.	Atacante con cuentas creadas en masa	M3	App Check con Play Integrity (H-06)

Nota. Modificar la app para entrar al panel de administración ya está mitigado: las reglas y las funciones validan el claim `admin` en el servidor.

Técnicas de auditoría

La guía exige al menos dos técnicas (Vacca, 2026); se usaron seis, todas automatizadas con scripts en `auditoria/scripts/` que guardan su salida con fecha y commit para poder repetir la prueba después de cada corrección (Tabla 3). Las pruebas dinámicas se hicieron con el APK de release instalado en un emulador Android 15. Por política del grupo no se inició sesión ni se crearon cuentas en el proyecto real de Firebase; las reglas se probaron en el emulador local de Firebase con un proyecto de demostración.

Tabla 3

Técnicas, herramientas y riesgos cubiertos

Técnica	**Herramienta**	**Riesgos**	**Alcance**
Secretos en código e historial	gitleaks 8.30.1 (Rice, 2025)	M1, M10	81 commits, todas las ramas y los archivos actuales
Dependencias	`flutter pub outdated`, `npm audit`	M2	Paquetes de Flutter y de Cloud Functions
Manifiesto y permisos	Script propio y `apkanalyzer`	M5, M6, M8	Manifiesto fuente y del APK, `Info.plist`
Análisis del APK de release	`apkanalyzer`, `apksigner`	M7, M8	Firma, depurable, símbolos en `libapp.so`, R8
Revisión de código	Lectura de reglas y 14 Cloud Functions; emulador de Firebase	M3, M4, M9	Autorización, validación, almacenamiento
Ejecución en emulador	Logcat y mitmproxy 12.3.1 (mitmproxy Project, 2025)	M5, M9	Arranque de la app sin sesión

Nota. El análisis con MobSF no se realizó porque Docker Desktop no arrancó en el equipo de trabajo. La prueba con mitmproxy no generó tráfico sin sesión y debe repetirse con una cuenta de prueba.

Resultados

Revisión del OWASP Mobile Top 10

La Tabla 4 resume el estado de cada riesgo en la versión auditada. Tres riesgos cumplen y siete no cumplen; el detalle de cada uno se presenta a continuación.

Tabla 4

Estado de los riesgos del OWASP Mobile Top 10 (2024) en la versión auditada

ID	Riesgo	Estado	Hallazgos
M1	Improper Credential Usage	No cumple	H-01
M2	Inadequate Supply Chain Security	No cumple	H-05
M3	Insecure Authentication/Authorization	No cumple	H-03, H-06
M4	Insufficient Input/Output Validation	Cumple	—
M5	Insecure Communication	Cumple	—
M6	Inadequate Privacy Controls	No cumple	H-07, H-08
M7	Insufficient Binary Protections	No cumple	H-04
M8	Security Misconfiguration	No cumple	H-01, H-07
M9	Insecure Data Storage	No cumple	H-02, H-09
M10	Insufficient Cryptography	Cumple	—

Nota. Riesgos según OWASP Foundation (2024a).

M1. Improper Credential Usage: no cumple

gitleaks marcó como `gcp-api-key` cuatro llaves de cliente de Firebase en el historial, en `lib/firebase_options.dart` y `android/app/google-services.json`. Google las trata como identificadores públicos cuyo acceso controlan las reglas (Google, s. f.-a), por lo que se aceptaron como falso positivo con la condición de restringirlas. La llave de Gemini está en Secret Manager y no aparece en el código. Sí hay una credencial expuesta: `debug.keystore`, con su contraseña escrita en Gradle, firmaba también el release (H-01).

```
gitleaks git --log-opts=--all   →  81 commits scanned · leaks found: 6
  4  gcp-api-key  lib/firebase_options.dart
  2  gcp-api-key  android/app/google-services.json
```

M2. Inadequate Supply Chain Security: no cumple

`npm audit` en `functions/` reportó diez vulnerabilidades transitivas, una de ellas alta en `body-parser` (H-05). En Flutter había versiones mayores pendientes de Firebase y ML Kit sin avisos de seguridad publicados.

M3. Insecure Authentication/Authorization: no cumple

Las once funciones invocables exigen sesión y las de administración verifican el claim `admin` en el servidor. Las reglas limitan cada colección a su dueña e impiden asignarse un rol desde el cliente. Sin embargo, una marca desactivada conservaba permisos de escritura y retirar el rol no revocaba la sesión (H-03). Tampoco había App Check (H-06), el mecanismo de Firebase para aceptar solo peticiones de la app legítima (Google, s. f.-b).

M4. Insufficient Input/Output Validation: cumple

Cada función valida tipos, largos y listas blancas: mensajes de chat de hasta 500 caracteres, límite de mensajes por minuto, identificadores sin barras y rutas de archivos temporales con un patrón estricto. Las reglas validan tipos y enumeraciones, y la app no declara deep links.

M5. Insecure Communication: cumple

La app no habilita tráfico en claro; con `targetSdk` 36 está bloqueado por defecto y todo el tráfico va por HTTPS a servicios de Google. No hay certificate pinning, que queda como mejora opcional.

M6. Inadequate Privacy Controls: no cumple

La colorimetría pide consentimiento y las selfies se borran después del análisis. Sin embargo, la app declaraba permisos de galería, micrófono y biometría que no usa (H-07) y cualquier usuaria podía leer la foto de perfil de otra (H-08).

M7. Insufficient Binary Protections: no cumple

El código Dart se compilaba sin ofuscar (H-04). R8 sí estaba activo en la parte Java del APK.

```
APK release (28fc2f7) — lib/arm64-v8a/libapp.so
  rutas "package:mackeupai/...dart" legibles:  209
  nombres: CredencialRepository · CapturasArRepository · asignarAdminMarca
classes.dex: 989 clases renombradas por R8 · apkanalyzer manifest debuggable → false
```

M8. Security Misconfiguration: no cumple

El release no es depurable y el único componente exportado propio es la actividad principal. Sin embargo, el release se firmaba con la llave de depuración pública (H-01) y pedía permisos de más (H-07).

M9. Insecure Data Storage: no cumple

`flutter_secure_storage` solo guarda el correo recordado y nunca contraseñas ni tokens. Sin embargo, las capturas AR del rostro se guardaban sin cifrar y entraban en el respaldo de Android (H-02), y 16 llamadas a `debugPrint` escribían en Logcat en release (H-09).

M10. Insufficient Cryptography: cumple

No se usan MD5, SHA-1, DES ni ECB, ni hay llaves embebidas. El único hash propio es SHA-256 para seudonimizar estadísticas en el servidor.

Hallazgos

La Tabla 5 registra los nueve hallazgos con el formato que pide la guía (Vacca, 2026), ordenados por severidad.

Tabla 5

Registro de hallazgos de la auditoría

ID	OWASP	Descripción	Evidencia	Sev.	Corrección propuesta
H-01	M1, M8	El release se firma con `debug.keystore`, publicado en el repositorio con su contraseña.	`build.gradle.kts` L31-44; `apksigner`: `CN=Android Debug`	Alta	Llave de release fuera del repositorio.
H-02	M9	Capturas AR del rostro sin cifrar e incluidas en el respaldo de Android.	`allowBackup` sin definir; `dumpsys`: `ALLOW_BACKUP`	Media	Desactivar el respaldo y excluir los datos.

ID	OWASP	Descripción	Evidencia	Sev.	Corrección propuesta
H-03	M3	Marca desactivada o ex-admin siguen escribiendo en el catálogo.	`firestore.rules` L131-139; `marcas.ts` L367	Media	Exigir marca activa y correo en `admins`; revocar sesión.
H-04	M7	Código Dart sin ofuscar en release.	209 rutas legibles en `libapp.so`	Media	Compilar con `--obfuscate`.
H-05	M2	Diez vulnerabilidades en dependencias de Functions.	`npm audit`: 1 alta, 8 moderadas, 1 baja	Media	`npm audit fix` y actualizar `firebase-admin`.
H-06	M3, M1	Backend sin App Check.	Sin `app_check` en el código	Media	App Check con Play Integrity.
H-07	M6, M8	Permisos que la app no usa (galería, micrófono, biometría).	Manifiesto del APK: 14 permisos	Baja	Quitarlos con `tools:node="remove"`.
H-08	M6	Fotos de perfil legibles por cualquier usuaria.	`storage.rules` L18-19	Baja	Lectura solo de la dueña o la admin.
H-09	M9	16 `debugPrint` activos en release.	Revisión de código	Baja	Silenciar `debugPrint` en release.

Correcciones

Se corrigieron ocho de los nueve hallazgos, empezando por el de mayor severidad, cada uno en su propio commit con su identificador en el mensaje (Tabla 6). Antes de cada commit se ejecutaron `flutter analyze`, `flutter test` (326 pruebas) y `npm test` (51 pruebas). Las correcciones siguen las guías de Android sobre respaldo automático, selector de fotos y firma de apps (Android Developers, s. f.-a, s. f.-b, s. f.-c) y la de Flutter sobre ofuscación (Flutter, s. f.).

Tabla 6

Correcciones aplicadas y mejora obligatoria que cubren

ID	Mejora obligatoria	Cambio	Commit
H-01	Ningún secreto en el repositorio	Release firmado con una llave propia (`key.properties` y `.jks` ignorados por Git); Gradle se detiene si falta.	`e85e1aa`
H-03	Permisos validados en el servidor	Reglas exigen marca activa y correo en `admins`; se revocan los refresh tokens al cambiar el rol.	`bca8a32`

ID	Mejora obligatoria	Cambio	Commit
H-02	Datos sensibles protegidos	`allowBackup="false"` y reglas de extracción que excluyen todo.	`868452b`
H-04	Release ofuscado y con R8	Build con `--obfuscate --split-debug-info`; símbolos fuera del repositorio.	`4d1386e`
H-09	Release sin logs sensibles	`debugPrint` vacío en release (`lib/main.dart`).	`f88462c`
H-05	Dependencias sin vulnerabilidades	`npm audit fix` y `firebase-admin` 14.5.1.	`0e8c8f5`
H-07	Mínimo privilegio	Se quitan seis permisos que la app no usa.	`2738357`
H-08	Mínimo privilegio	Foto de perfil legible solo por su dueña o la admin.	`32401ed`

Nota. H-06 no se implementó porque App Check exige registrar la app en Play Integrity desde la consola de Firebase. Las reglas y funciones corregidas deben publicarse con `firebase deploy`.

Verificación

Se repitió la misma prueba de cada hallazgo sobre la versión auditada y sobre la rama corregida (Tabla 7). Un hallazgo solo se consideró cerrado si la prueba repetida ya no lo reproducía.

Tabla 7

Resultado de las pruebas antes y después de cada corrección

ID	Prueba	Antes	Después	Cerrado
H-01	`apksigner verify`	`CN=Android Debug` (llave del repositorio)	`CN=MackeUp AI, O=UNICESAR` (llave propia)	Sí
H-02	`dumpsys package`	Bandera `ALLOW_BACKUP`	Sin `ALLOW_BACKUP`	Sí
H-03	Emulador de reglas	Ex-admin y marca desactivada escriben (200)	Ambas reciben 403; la admin vigente, 200	Sí
H-04	Rutas en `libapp.so`	209 rutas y nombres de clases	0 rutas; sin nombres de clases	Sí
H-05	`npm audit`	10 (1 alta)	7 moderadas, 0 altas	Parcial
H-07	Permisos del APK	14, con micrófono y almacenamiento	8, sin micrófono, almacenamiento ni biometría	Sí
H-08	Emulador de reglas	Otra usuaria lee la foto (200)	Otra usuaria, 403; la dueña, 200	Sí

ID	Prueba	Antes	Después	Cerrado
H-09	Código y Logcat del release	16 `debugPrint` activos	Ninguna línea de la app en Logcat	Sí

Nota. La prueba de reglas usa el emulador local de Firebase con el proyecto `demo-auditoria`, sin acceso al proyecto real.

```
probar_reglas.ps1 -Commit 28fc2f7  →  Resultado: 4 caso(s) no cumplen
probar_reglas.ps1  (corregido)     →  Resultado: todas las reglas se comportan como
se espera
npm audit   antes: 10 vulnerabilities (1 low, 8 moderate, 1 high)   después: 7
moderate
```

Discusión

La base de seguridad de MackeUp AI es sólida: la autorización y la validación de entradas se hacen en el servidor, los secretos del backend están en Secret Manager y el dispositivo no guarda contraseñas ni tokens. Los problemas encontrados fueron sobre todo de configuración del build y de permisos, que suelen pasar desapercibidos porque la app funciona igual con ellos.

El hallazgo H-05 quedó cerrado de forma parcial. Las siete vulnerabilidades moderadas restantes están anidadas en los SDK de Google (`gaxios`, `uuid`, `rimraf`, `glob` y `minimatch`) y solo podrían eliminarse forzando versiones mayores, con riesgo de romper las funciones en producción. Ninguna tiene una ruta de ataque en este backend, por lo que se aceptaron como riesgo residual que se revisará con cada actualización de `firebase-admin`.

Quedan pendientes para el equipo publicar las reglas y funciones corregidas, crear la llave de publicación definitiva y registrar sus huellas en Firebase, repetir con una cuenta de prueba las pruebas de mitmproxy y Logcat con sesión iniciada, e integrar App Check como mejora opcional.

Referencias

Android Developers. (s. f.-a). *Back up user data with Auto Backup*. Google. https://developer.android.com/identity/data/autobackup

Android Developers. (s. f.-b). *Photo picker*. Google. https://developer.android.com/training/data-storage/shared/photopicker

Android Developers. (s. f.-c). *Sign your app*. Google. https://developer.android.com/studio/publish/app-signing

Flutter. (s. f.). *Obfuscate Dart code*. Google. https://docs.flutter.dev/deployment/obfuscate

Google. (s. f.-a). *Learn about using and managing API keys for Firebase*. Firebase. https://firebase.google.com/docs/projects/api-keys

Google. (s. f.-b). *Firebase App Check*. Firebase. https://firebase.google.com/docs/app-check

Holloway-George, E. (2024, febrero). *What's the buzz about the 2024 OWASP Mobile Top 10 changes?* ProAndroidDev. https://proandroiddev.com/whats-the-buzz-about-the-2024-owasp-mobile-top-10-changes-83c93f765bd3

mitmproxy Project. (2025). *mitmproxy* (Versión 12.3.1) [Software]. https://mitmproxy.org

OWASP Foundation. (2024a). *OWASP Mobile Top 10*. https://owasp.org/www-project-mobile-top-10/

OWASP Foundation. (2024b). *OWASP Mobile Application Security Verification Standard (MASVS)* (Versión 2.1.0). https://mas.owasp.org/MASVS/

OWASP Foundation. (2026). *OWASP Mobile Application Security Testing Guide (MASTG)* (Versión 2.0.0). https://mas.owasp.org/MASTG/

Rice, Z. (2025). *Gitleaks* (Versión 8.30.1) [Software]. GitHub. https://github.com/gitleaks/gitleaks

Vacca, A. (2026). *Tarea: Seguridad en aplicaciones móviles* [Guía de actividad, Programación Móvil]. Universidad Popular del Cesar.